DOI:10.16644/j.cnki.cn33-1094/tp.2022.10.008

网络安全虚拟仿真靶场设计与实现*

毕晓东

(浙江经济职业技术学院，浙江 杭州 310018)

摘　要：为了提升网络安全人才的攻防技术、研究能力和实战能力，设计了虚拟仿真靶场。该平台应用Docker容器虚拟化技术+开源漏洞靶场，模拟企业实战环境，搭建案例化、场景化靶场环境。借助centos安装Docker靶机，采用windows和kali作为渗透攻击机进行测试。最终，搭建出一个全流程、高仿真、启动快，资源占用小、利用高的准安全攻防靶场运行环境。此方案为网络安全专业人才的培养提供了平台支撑和操作借鉴。

关键词：Docker；虚拟化；漏洞；靶场

中图分类号：TP393　　**文献标识码：**B　　**文章编号：**1006-8228(2022)10-29-04

Design and implementation of network security virtual simulation shooting range

Bi Xiaodong

(*Zhejiang Technical Institute of Economics, Hangzhou, Zhejiang 310018, China*)

Abstract: In order to improve the offensive and defensive technology research and practical ability of network security talents, a virtual simulation shooting range is designed. Docker container virtualization technology + open source vulnerability shooting range is applied to simulate the real combat environment of enterprises, and build case-based and scenario-based shooting range environment. Docker target is installed with CentOS, and Windows and Kali are used as penetration attack machines for testing. Finally, a quasi security attack and defense shooting range operation environment with whole process, high simulation, fast startup, small resource occupation and high utilization is built. It provides platform support and operational reference for the training of network security professionals.

Key words: Docker; virtualization; vulnerability; shooting range

0 引言

在数字化时代，网络空间安全议题已上升到国家战略层面，受到各国高度重视[1]。网络安全的问题复杂而突出，这对网络安全人才的培养提出了更高的要求。

在网络安全人才培养过程中需要提供实战环境。通过网络安全仿真技术，快速、低成本的构建仿真网络安全靶场环境，支撑用户在该环境中开展真实的大范围网络攻防演练、应急演练、培训教育，测试和评估网络环境安全和网络设施的薄弱环节，帮助用户预防未知威胁和攻击，提升安全防护能力。美国2009年1月启动了“国家网络靶场”项目，并于2011年10月完成了原型开发。通过模拟真实的电子对抗和网络攻击，用来对未来可能发生的网络战争进行推演。目前高校网络安全专业在网络安全人才培养方面，网络靶场也有着重要应用价值，可以为网络安全技术研究、学习、攻防对抗演练等提供安全、仿真的实验实训攻防环境[2]。近几年，针对网络安全人才培养开发的网络靶场实训平台，在高校人才培养中发挥着十分重要的作用。

1 Docker技术解析

Docker是基于Go语言实现的开源项目，其可以通过对应用组件的封装、开发、部署、运行等生命周期

收稿日期：2022-03-21

***基金项目：**浙江教育厅访工课题项目“基于Docker的网络安全靶场设计与实现”(FG2021265)

作者简介：毕晓东(1979-)，男，河南南阳人，工程硕士，副教授，主要研究方向：计算机网络，信息安全，教学技术。

的管理，使用户的机器运行环境能够做到“一次封装，到处运行”[3]。Docker可以轻松创建，运行和分发应用程序。应用程序打包了运行应用程序所需的所有内容。该技术保证容器可以在每个Docker运行环境上运行。

Docker技术具有以下优点：

● 再生性：使用Docker时，可以确保软件产品（应用程序，数据分析，预测模型等）在所有docker运行时环境中运行。因为容器包含运行工程所需的一切，它不仅分发代码，还分发环境。

● 一致性：Docker提供了一个统一且一致的运行环境，适用于各种软件产品。它减少了系统管理的时间，更专注于核心工作。Docker类似于整个软件生态系统[4]。

● 可追溯性：Docker容器是根据脚本构建的，该脚本在必要的软件依赖和环境下是可读摘要的。这种脚本可以受版本控制。脚本完全可以通过这种方式跟踪；Docker容器可以存储在组织内的存储库中，从而以这种方式保留整个版本的历史记录[5]。

● 可移植性：Docker容器可以轻松地从一个Docker环境移植到另一个Docker环境。DockerSwarm（或Kubernetes）允许自动扩展应用程序，从而减少系统管理和操作的成本。

● 轻量化：在一台机器上运行的多个Docker容器可以共享这台机器的操作系统内核；能快读的启动，而只需占用很少的计算和内存资源。镜像是通过文件系统层进行构造的，并共享一些公共文件，这样就能尽量降低磁盘用量，并能更快地下载镜像[6]。

● 安全：Docker赋予应用隔离性，不仅彼此隔离，还独立于底层的基础设施。默认提供最强的隔离，因此应用出了问题，隔离在单个容器内，不会波影响到整台机器。

2 基于Docker的网络靶场设计与构建

2.1 拓扑设计

本靶场设计以医疗行业为背景，基于真实医院网络场景，模拟出内部网络、生产网络、外部网络，拓扑图如图1所示。其中攻击机采用KaliLinux，而靶机采用CentOS，充分仿真真实的攻击场景。

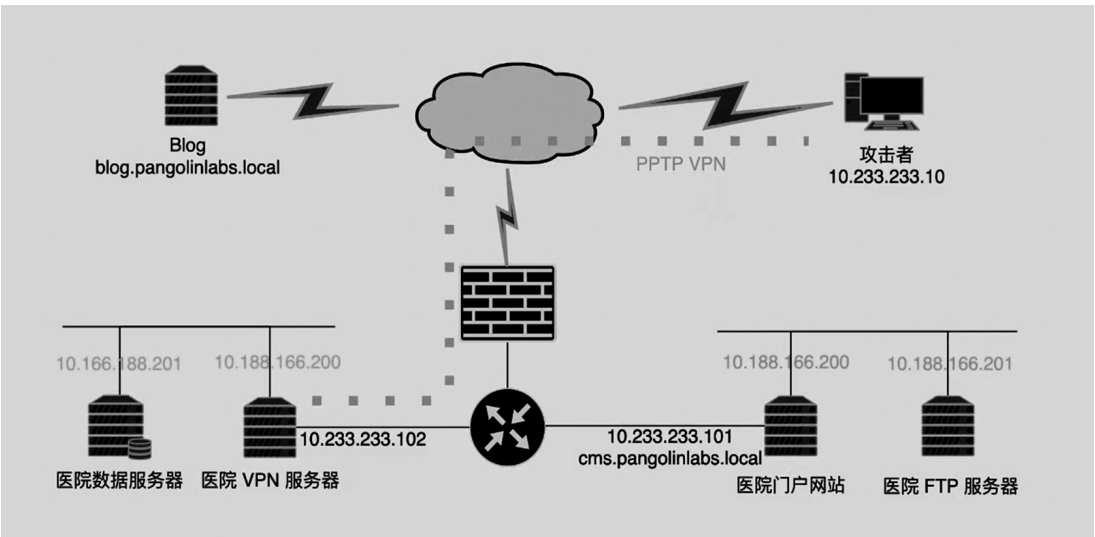

图1 行业网络安全仿真靶场拓扑设计

① 外网设计

博客服务器部署在外网，外网上的服务器可以直接访问博客服务器。在博客服务器上使用Joomla3.4部署了一个博客网站（这个版本的Joomla包含一个严重的SQL注入漏洞，这里是渗透的一个关键入口）。可以利用这个漏洞获得管理员的账号密码。

② 内网设计和实现

医院门户网站服务器和医院FTP服务器所在的网络属于内网，处于防火墙之后，需要通过路由网关访问。

网站服务器上使用yxcms部署了一个门户网站，可以在登录后台后通过挂马来连接服务器后门（服务器的系统为CentOS6.5，其内核存在赃牛漏洞，可以用于提权，作为内网渗透的跳板机）。

FTP服务器采用VSFTP2.3.4，这个版本的VSFTP存在著名的笑脸漏洞，可以利用此漏洞获取服务器权限。

③ 生产网设计和实现

VPN服务器和数据服务器所在的网络属于生产网，需要通过VPN才能访问。VPN服务器采用openvpn部署，连接VPN服务器后才能访问生产网中的数据服务器。

数据服务器使用MySQL部署，数据库中的数据就是最终目标。此服务器root账号使用了弱密码，攻击者可以通过暴力破解获得root权限，最后得到目标数据。

2.2 网络靶场主要功能

- 信息取证（磁盘恢复、内存分析、PDF审计、注册表审计）
- 渗透测试评估网络系统安全
- Web服务器、ftp服务器渗透、提权
- 攻击WPA/WPA2保护的无线网络（获取WiFi密码、网络嗅探）
- 破解密码（离线破解哈希密码、在线破解网站登录密码）
- 逆向工程（将android、Java、C++编写的程序反编译成代码）

靶场主要靶机漏洞包括JoomlaSQL注入漏洞、Linux内核赃牛漏洞、VSFTP笑脸漏洞。

① Joomla

是一套自由、开放源代码的内容管理系统，以PHP撰写，用于发布内容在万维网与内部网，通常被用来搭建商业网站、个人博客、信息管理系统、Web服务等，还可以进行二次开发以扩展使用范围。其功能包含可提高性能的页面缓存、RSS馈送、页面的可打印版本、新闻摘要、博客、投票、网站搜索、与语言国际化[7]。

② 脏牛漏洞(CVE-2016-5195)

是公开后影响范围最广和最深的漏洞之一，Linuxkernel>=2.6.22（2007年发行，到2016年10月18日才修复）的Linux版本，包括Android、桌面版和服务器版都受到其影响。恶意攻击者通过该漏洞可以轻易地绕过常用的漏洞防御方法，对几百万的用户进行攻击[8]。

③ VSFTP

VSFTP是一个基于GPL发布的类Unix系统上使用的FTP服务器软件，VSFTP2.3.4版本存在恶意后门，远程攻击者可利用这个问题控制受影响系统。使用ftp客户端连接含有漏洞的FTP服务器，输入用户名时以笑脸符号：)结尾，含有漏洞的VSFTP程序便会在服务器上开启后门，连接此后门就可以控制服务器。

3 靶场测试

3.1 攻击流程

攻击测试以黑客视角，从外网来渗透，整个过程设置多个节点，主要考察使用者多种网络渗透能力，近乎实战场景，可以通过黑客视角，了解和掌握攻击方法和手段。有助于网络安全人才更好的提升网络安全防御思维和能力。

① 第一步：扫描医院门户网站获取有效信息。

通过对门户CMS网站信息探查cms服务器地址为192.168.1.2，接着，查看robots.txt访问http://192.168.1.2/robots.txt，发现没有可以利用的信息，接下来进行网站敏感文件扫描，获得敏感信息。

② 第二步：利用上一步得到敏感信息进行社工，找到博客网站。

在敏感文件中发现一个特殊的200][application/zip][2.87mb]、使用浏览器访问下载后解压，发现是网站的源代码备份，查找网站内可以利用的信息（发现管理员的个人博客地址192.168.1.222）

③ 第三步：利用博客网站漏洞获取管理员账号密码。

访问博客。发现博客是基于joomla搭建，首先尝试访问joomla的默认后台地址http://192.168.1.222/administrator/，可以访问，但是没有账户密码，使用默认账户密码尝试猜解，没有成功，进一步访问http://192.168.1.222/README.txt获取更多信息（发现joomla的版本为3.4，根据这个信息来搜索漏洞完成入侵）。接下来使用kali，打开Mestasploit执行攻击命令，借助XBruteForcer工具，并设置字典进行暴力破解，获得账号、密码存放在同文件夹下的Result.txt中。

④ 第四步：尝试用上一步得到的账号密码登录门户网站。

猜测cms网站管理员账户密码与博客网站账户密码相同，尝试使用上文得到的后台路径和账户密码登入后台，成功登录后，在kali上用weevely工具完成此操作，使用命令安装，安装成功后，创建木马文件（具体命令weevelygeneratehellohook.php）

⑤ 第五步：进入门户网站后台，植入木马后门。把木马文件上传到cms网站，经测试没有找到可以直接上传php的地方，因此采用新建的方式代替。具体操作：登录cms网站的管理员后台，然后在cms网站管理界面依次点击管理首页->前台模板->管理模板文

件->新建取名为hook.php，最后把生成的php文件的内容粘贴上去，如图2所示。

图2　通过后台管理功能添加后门程序文件

⑥ 第六步：连接植入的木马后门，并利用赃牛漏洞提权。

后门创建成功，就可以直接访问。为了维持控制权限，就要进行提权操作，使用命令uname-a查看操作系统的内核版本信息，发现内核版本为2.6.32-431.el6.x86_64（此版本含有赃牛漏洞），接下来使用赃牛漏洞实现提权。在终端执行nc -vv -l -p12388命令来监听反弹shell。

⑦ 第七步：渗透内网，扫描到FTP服务器，并利用笑脸漏洞获取权限。

在第六步获取的cms服务器的rootshell中，安装nmap（yuminstall -y nmap），并对内网进行扫描（nmap-p21,22,80192.168.1.0/24），扫描后，发现内网ftp服务器，进一步对ftp服务器扫描，发现版本为vsftp2.3.4（此版本的vsftp含有笑脸漏洞），利用漏洞进行攻击。

⑧ 第八步：在FTP服务器上找到包含VPN账号密码信息的文件，连接VPN。

⑨ 第九步：通过VPN连入生产环境后扫描到数据服务器，暴力破解root账户。

⑩ 第十步：使用root权限修改mysql数据库密码，连接数据库，获得数据库敏感信息。

最终完成全部渗透流程。通过以上步骤可以掌握主流的漏洞利用技术，提升网络渗透能力，使学生以攻击者视角去理解攻击全流程，从而提升培养网络安全意识和网络加固技术，做到“知攻能防”。进而全方位提升学生整体网络安全运维和防护能力。

4 结束语

基Docker的网络安全虚拟仿真靶场可以模拟真实企业网络场景，提供真实仿真的企业实战环境，方便快速部署各种常见的服务和漏洞，这种模式具有轻量化、易部署、易管理的特点。该靶场在网络安全专业的项目实训室有着广泛的应用前景。目前该平台还缺少整个过程的记录，不能把实验数据实时反馈给学生，接下来还要在此平台上融入实训评价系统，使该平台成为具备网络攻防实训和测评、学生画像数据分析、反馈功能的综合仿真实训平台。

参考文献(References):

[1] 章秀，刘宝旭，龚晓锐，等.Explore-Exploit:一种模拟真实网络渗透场景的安全竞赛[J].信息安全学报，2020,5(4):55-71

[2] 周云峰，叶大区.通过实战攻防演练，审视政务网络安全体系建设[J].中国信息安全，2019,109(1):45-47

[3] 沈雪石.网络空间攻防技术发展动向分析[J].国防科技，2017(4):47-51

[4] 朱贤斌.建设基于云计算环境下的攻防演练平台[J].网络安全和信息化，2019,33(1):106-109

[5] 李春林，刘正军，王冶，等.一种改进的基于Docker的网络安全实验平台构建方法[J].通信技术，2019,52(4):927-932

[6] 吴怡晨.网络空间攻防靶场的设计和构建技术研究[D].上海：上海交通大学，2018

[7] 董博，王雪，索菲，等.基于Docker的虚拟化技术研究[J].辽宁大学学报(自然科学版)，2016,43(4):327-330

[8] 肖小芳，宋建新.Docker网络通信研究与实现[J].通讯世界，2017(22):1-2

主办单位简介

浙江天正信息科技有限公司，前身为浙江省计算技术研究所，成立于1974年，隶属于浙江省科学技术厅，是浙江省最早从事计算机技术及其应用开发的专业研究所。主要经营方向为：软件开发、信息技术咨询和培训、系统集成、工业自动控制。

公司相关资质证书：

- 信用等级证书AAA级
- 质量管理体系认证证书 ISO9001:2008
- 高新技术企业证书
- 计算机信息系统集成企业资质证书 叁级
- 涉及国家秘密的计算机信息系统集成资质证书 乙级
- 工程设计与施工资质证书 壹级